

1. Purpose and scope

This policy defines how Northwind Analytics protects the confidentiality, integrity and availability of its information assets. It applies to all employees, contractors, interns and third parties who access company systems or data, on any device, in any location.

2. Data classification

All information must be classified into one of four levels. Public: approved for release outside

the company. Internal: default for day-to-day business information; not for external release.

Confidential: commercially sensitive information, including contracts, financial forecasts and

unreleased product plans. Restricted: personal data, authentication secrets, security findings and

anything whose disclosure would cause severe harm. Restricted data may only be processed on managed

devices and may never be copied to personal storage or unapproved cloud services.

3. Access control

Access is granted on the principle of least privilege and must be approved by the data owner.

All accounts require multi-factor authentication. Passwords must be at least 14 characters, generated by the company password manager, and unique to each system. Shared accounts are prohibited. Access rights are reviewed quarterly, and are revoked within 24 hours of an employee

leaving or changing role.

4. Device security

Company laptops and phones must have full-disk encryption enabled, an automatic screen lock after

10 minutes of inactivity, and the managed endpoint agent installed and running. Operating system

and browser updates must be applied within 14 days of release, and within 48 hours where the update fixes a vulnerability rated critical. Personal devices may access company email and chat

only through the managed application container.

5. Acceptable use

Company systems are provided for business use. Incidental personal use is permitted where it does

not interfere with work, incur cost, or introduce risk. Staff must not disable security controls,

connect unapproved devices to the corporate network, install unlicensed software, or use generative

AI services with Confidential or Restricted data unless the service appears on the approved list maintained by the security team.

6. Incident reporting

Any suspected or actual security incident must be reported to the security team within one hour of discovery, by email to security@northwind.example or by calling the 24-hour security hotline.

Reportable events include lost or stolen devices, suspected phishing, accidental disclosure of data, malware alerts and unauthorised access. Staff must not attempt to investigate or remediate an incident themselves, and must preserve evidence, including keeping the affected device powered on and connected. The security team acknowledges every report within two hours and assigns a severity within four hours. Incidents rated severity 1 are escalated to the executive team immediately and regulators are notified within 72 hours where personal data is involved.

7. Third parties and suppliers

Suppliers who process company data must complete a security assessment before contract signature and must be re-assessed annually. Contracts must include breach notification within 24 hours, a right to audit, and defined data deletion obligations at the end of the engagement. Third-party access is time-limited and granted through the supplier portal, never by sharing staff credentials.

8. Data retention and disposal

Business records are retained for seven years unless a longer statutory period applies. Personal data is retained only as long as needed for the purpose it was collected for, as recorded in the processing register. Electronic media is wiped to the current NIST purge standard before disposal, and paper records containing Confidential or Restricted information are cross-cut shredded.

9. Business continuity

Critical systems are backed up daily, with backups replicated to a second region and tested by restore at least twice a year. The recovery time objective for critical systems is four hours and the recovery point objective is one hour.

10. Compliance and exceptions

Breaches of this policy may lead to disciplinary action up to and including dismissal, and to termination of contract for third parties. Exceptions must be requested in writing, carry a business justification and a compensating control, and are approved by the Chief Information Security Officer for a maximum of 90 days. This policy is reviewed annually, or sooner after a severity 1 incident or a material change in regulation.